

MAINCRAFTS TECHNOLOGY

Cybersecurity & Ethical Hacking Internship Program

Threat Intelligence Report

Cybersecurity Task — 1

Prepared By: Abhishek Verma

Institution: MIT Academy of Engineering, Pune

Program: Cybersecurity Analyst Intern Simulation — Maincrafts Technology

Task: Task-1 — Threat Report (Awareness & Research Project)

Date: June 2026

Table of Contents

- 1. Introduction to Cybersecurity
- 2. Five Major Modern Cyber Threats (2024–2025)
- 3. Impact Analysis
- 4. Real-World Case Studies
- 5. Preventive Measures
- 6. Conclusion & Future Scope
- 7. References

1. Introduction to Cybersecurity

What is Cybersecurity?

Cybersecurity refers to the collection of technologies, processes, and practices designed to protect digital systems, networks, and data from unauthorized access, disruption, theft, or damage. It is a discipline that spans everything from securing a single personal device to defending the digital backbone of entire nations. The foundational framework of cybersecurity rests on three core principles — the CIA Triad: Confidentiality, which ensures information is accessible only to authorized parties; Integrity, which guarantees that data remains accurate and unaltered; and Availability, which ensures that systems and information are accessible when legitimately needed.

Why It Matters — For Individuals and Businesses

We live in an era where an individual's financial history, medical records, private communications, and personal identity all exist in digital form — and are therefore targets. For individuals, a single compromised account can cascade into identity theft, financial ruin, and lasting personal harm. For businesses, the consequences extend far beyond the immediate incident. Loss of customer data triggers regulatory penalties, civil liability, and public scrutiny that can permanently erode brand trust built over years.

IBM's Cost of a Data Breach Report 2024 placed the average global cost of a breach at \$4.88 million — a record high. For small and medium enterprises, an incident of this scale is frequently existential. The financial case for proactive security investment has never been clearer.

Current Relevance

The threat environment of 2024–2025 is shaped by several converging realities that make cybersecurity more urgent than at any previous moment:

- Global cybercrime damages are forecast to reach \$10.5 trillion annually by 2025, surpassing the GDP of most nations (Cybersecurity Ventures).
- The shift to remote and hybrid work has permanently expanded the enterprise attack surface, with home networks and personal devices becoming entry points into corporate infrastructure.
- Artificial intelligence is now actively weaponized by threat actors to automate attacks, generate convincing fraudulent content, and evade traditional signature-based detection systems.
- Critical infrastructure — power grids, water systems, financial networks, and healthcare systems — is under sustained, targeted attack from both state-sponsored actors and organized criminal groups.

2. Five Major Modern Cyber Threats (2024–2025)

The five threats presented below were selected to represent a diverse cross-section of the 2024–2025 threat landscape — spanning human-targeted deception, infrastructure attacks, supply chain compromise, and threats from within organizations themselves.

Threat 1 — AI-Powered Phishing Attacks

Phishing has existed since the early days of email, but artificial intelligence has transformed it from a blunt, scattergun tactic into a precision instrument. Modern AI-powered phishing campaigns use large language models to craft emails that are grammatically flawless, contextually relevant, and indistinguishable from legitimate correspondence. Attackers mine public data — LinkedIn profiles, company press releases, social media — to build detailed profiles of targets and craft messages that reference real colleagues, real projects, and real organizational context.

The consequences extend beyond email. AI-generated voice clones and deepfake video calls are now being used to impersonate senior executives in real-time conversations, convincing employees to transfer funds, share credentials, or grant system access. The human brain is not equipped to reliably detect deception at this level of sophistication — which is precisely why AI-powered phishing has become one of the most effective and financially destructive attack vectors in the current landscape.

Threat 2 — Supply Chain Attacks

A supply chain attack occurs when a threat actor compromises a trusted third-party vendor, software provider, or service partner as a means of gaining access to their downstream customers. Rather than attacking a well-defended target directly, attackers identify and exploit weaker links in the supply chain — inserting malicious code into software updates, compromising build pipelines, or hijacking shared infrastructure — and use that access to propagate into thousands of organizations simultaneously.

What makes supply chain attacks particularly devastating is the element of trust. When an organization installs a software update from a vendor they have used for years, they are not checking it for malicious code. Attackers exploit this implicit trust to achieve a scale of compromise that would be impossible through direct attacks on individual targets. The 2020 SolarWinds incident demonstrated that a single supply chain compromise can simultaneously affect thousands of enterprises and government agencies across multiple countries.

Threat 3 — Insider Threats

Not all threats originate from outside an organization. Insider threats — malicious or negligent actions by employees, contractors, or trusted partners with legitimate system access — represent one of the most difficult security challenges precisely because conventional perimeter defenses offer no protection against them. Insiders already have the access, the context, and in many cases, the motive.

Insider threats broadly fall into two categories. Malicious insiders deliberately steal data, sabotage systems, or sell access to external actors — often motivated by financial gain, grievance, or coercion. Negligent insiders, while not acting with harmful intent, cause significant damage through poor security hygiene: clicking phishing links, misconfiguring systems, sharing credentials, or mishandling sensitive data. According to the Ponemon Institute's 2024 Cost of Insider Risk Report, insider incidents cost organizations an average of \$16.2 million annually — and take an average of 86 days to contain.

Threat 4 — Distributed Denial-of-Service (DDoS) Attacks

A Distributed Denial-of-Service attack overwhelms a target system, server, or network with a flood of traffic from thousands or millions of compromised devices — rendering it unable to serve legitimate users. DDoS attacks do not steal data or compromise systems in the traditional sense; their weapon is disruption. For businesses that depend on continuous online availability — e-commerce platforms, financial institutions, healthcare portals, gaming services — even minutes of downtime translate directly into revenue loss and reputational harm.

Modern DDoS attacks have grown dramatically in both scale and sophistication. Attackers now deploy application-layer attacks that mimic legitimate user behavior, making them far harder to filter than volumetric floods. The rise of IoT botnets has provided attackers with vast pools of compromised devices to weaponize. In 2024, Cloudflare reported mitigating a DDoS attack peaking at 5.6 terabits per second — the largest ever recorded at that time.

Threat 5 — Social Engineering & Deepfakes

Social engineering is the art of manipulating people rather than machines. Instead of exploiting a software vulnerability, social engineering exploits human psychology — trust, urgency, authority, fear, and helpfulness. It encompasses a broad range of tactics: pretexting (fabricating a convincing scenario to extract information), baiting (leaving infected USB drives in public spaces), quid pro quo attacks (offering something in exchange for credentials), and tailgating (physically following authorized personnel into restricted areas).

Deepfake technology has added a new and deeply concerning dimension to social engineering. Using AI-generated audio and video, attackers can now fabricate realistic impersonations of executives, government officials, or family members in real time. These fabrications are used to authorize fraudulent financial transactions, manipulate employees into bypassing security controls, or spread disinformation that damages reputations and influences decisions. As deepfake generation becomes cheaper and more accessible, the boundary between real and fabricated communication is becoming dangerously difficult to discern.

3. Impact Analysis

Each threat carries distinct consequences depending on the target. Understanding the human and organizational dimensions of each threat helps security professionals and decision-makers prioritize protective measures and communicate risk effectively.

AI-Powered Phishing

Individuals: Individuals face credential theft leading to unauthorized account access, financial fraud, identity theft, and in deepfake-enabled cases, severe psychological distress from fabricated content involving their likeness or the voices of people they trust.

Organizations: Organizations suffer Business Email Compromise losses — the FBI recorded over \$2.9 billion in BEC losses in 2023 alone — alongside unauthorized wire transfers, executive impersonation fraud, credential compromise leading to broader network intrusions, and erosion of employee trust in internal communications.

Supply Chain Attacks

Individuals: Individuals may have personal data exposed through breaches of services they rely on, with little awareness that the compromise originated several layers removed from the software they actually use.

Organizations: Organizations face systemic compromise through software or services they explicitly trust, making detection extremely difficult. Consequences include mass data exfiltration, regulatory violations, extended dwell time for attackers within internal networks, and reputational damage extending to their own customers who were affected downstream.

Insider Threats

Individuals: Individuals — particularly employees involved in incidents, whether malicious or negligent — face career consequences, legal liability, and in cases of coerced insiders, personal safety risks.

Organizations: Organizations experience data theft, intellectual property loss, deliberate sabotage of critical systems, compliance violations, and the compounding challenge that insider incidents are significantly harder to detect than external attacks. The average cost per insider incident reached \$16.2 million in 2024, with containment taking nearly three months.

DDoS Attacks

Individuals: Individuals experience service unavailability — inability to access banking, healthcare portals, or essential services — with limited direct harm unless the DDoS is used as a smokescreen for a concurrent data breach.

Organizations: Organizations face direct revenue loss from downtime, SLA penalties, customer churn, and reputational damage. For financial institutions and e-commerce platforms, a prolonged DDoS attack during peak periods can result in millions of dollars in losses per hour. Attackers increasingly use DDoS as a distraction to divert security teams while a separate breach operation proceeds undetected.

Social Engineering & Deepfakes

Individuals: Individuals are vulnerable to financial fraud through impersonation of family members or institutions, reputational harm from fabricated deepfake content, and emotional manipulation that can be difficult to identify and even harder to prove after the fact.

Organizations: Organizations face unauthorized financial transfers initiated through executive impersonation, security control bypass by employees deceived into granting access, disinformation campaigns targeting brand reputation, and the erosion of internal trust in communication channels — a cultural cost that is difficult to quantify but significant in impact.

4. Real-World Case Studies

The following incidents are drawn from publicly documented events and directly correspond to the five threat categories covered in this report. They illustrate how these threats materialize in practice and the scale of damage they are capable of causing.

Case Study 1 — Arup Group AI Voice Fraud (2024)

Category: *AI-Powered Phishing*

In early 2024, a finance employee at Arup — one of the world's largest engineering consultancies — was deceived into transferring \$25 million to fraudulent accounts after participating in a video call with what appeared to be the company's CFO and several colleagues. Every participant on the call was an AI-generated deepfake. The employee had initial doubts about the legitimacy of the request but was reassured by seeing familiar faces and hearing familiar voices. The incident marked one of the first confirmed large-scale financial frauds executed entirely through deepfake video conferencing, and it signaled a new frontier in AI-enabled social engineering that organizations had not yet built defenses against.

Case Study 2 — SolarWinds Supply Chain Attack (2020–2021)

Category: *Supply Chain Attack*

In late 2020, it was revealed that Russian state-sponsored threat actors — later attributed to the SVR group known as Cozy Bear — had compromised the build pipeline of SolarWinds, a widely used IT management software vendor. A malicious backdoor was embedded into a routine software update for the Orion platform, which was subsequently distributed to approximately 18,000 SolarWinds customers. Among the organizations compromised were the U.S. Departments of Treasury, Commerce, Homeland Security, and State, as well as major technology firms including Microsoft and FireEye. Attackers maintained undetected access for up to nine months. The SolarWinds attack remains the definitive modern example of the catastrophic potential of supply chain compromise executed at scale.

Case Study 3 — Tesla Insider Sabotage (2018) and Ubiquiti Insider Extortion (2021)

Category: *Insider Threat*

In 2018, a disgruntled Tesla employee sabotaged the company's manufacturing operating system and exfiltrated gigabytes of proprietary data before sending it to external parties — demonstrating how a single malicious insider with legitimate access can cause irreparable harm to intellectual property. In a separate and striking case in 2021, a former Ubiquiti engineer used his administrative access to steal confidential data, then posed anonymously as an external hacker and attempted to extort the company for \$1.9 million in cryptocurrency while simultaneously leaking stories to the press suggesting the breach was more severe than disclosed. He was later convicted. Together, these cases illustrate the two faces of the insider threat — impulsive sabotage and calculated, long-term exploitation.

Case Study 4 — GitHub DDoS Attack (2018) and Cloudflare Record Attack (2024)

Category: *DDoS Attack*

In February 2018, GitHub was struck by what was then the largest DDoS attack ever recorded, peaking at 1.35 terabits per second. The attack exploited misconfigured Memcached servers to amplify traffic by a factor of 51,000 — meaning each byte sent by the attacker generated 51,000 bytes of traffic directed at GitHub. The platform was intermittently unavailable for approximately ten minutes before traffic scrubbing services absorbed the attack. In 2024, Cloudflare reported mitigating a new record-breaking DDoS attack peaking at 5.6 terabits per second — demonstrating that attack volumes are continuing to grow year over year as IoT botnets and amplification techniques become increasingly accessible to attackers.

Case Study 5 — Ferrari CEO Deepfake Attempt (2024)

Category: *Social Engineering & Deepfakes*

In 2024, a senior Ferrari executive received a series of WhatsApp messages and a phone call from what appeared to be Ferrari CEO Benedetto Vigna — complete with an AI-cloned voice that accurately replicated his tone, accent, and speaking style. The impersonator requested an urgent and confidential business transaction. The executive grew suspicious when the caller could not answer a personal verification question, and the attempt was foiled. Ferrari subsequently introduced verbal codewords for verifying the identity of senior executives in sensitive communications. This incident illustrates that even well-prepared organizations with security-aware leadership are vulnerable to AI-generated voice cloning — and that low-tech countermeasures, like shared passphrases, remain effective defenses.

5. Preventive Measures

Defense against modern threats requires a layered strategy — no single control is sufficient on its own. The following measures are mapped to each threat and reflect current best practices recommended by CISA, NIST, ENISA, and leading security practitioners.

Against AI-Powered Phishing

- Deploy AI-native email security platforms that analyze behavioral signals, sender reputation, and contextual anomalies — not just known malicious signatures — to catch sophisticated, targeted phishing attempts.
- Enforce Multi-Factor Authentication (MFA) across all accounts so that stolen credentials alone cannot result in account takeover, even when phishing is successful.
- Train employees specifically on AI-generated threats — including how to recognize deepfake video calls, voice cloning attempts, and hyper-personalized spear phishing — rather than relying on generic security awareness programs.
- Implement DMARC, DKIM, and SPF email authentication protocols to prevent attackers from spoofing trusted organizational domains.

Against Supply Chain Attacks

- Conduct thorough vendor security assessments before onboarding third-party software or service providers, and establish ongoing monitoring of vendor security posture throughout the relationship.
- Apply software composition analysis tools to audit third-party libraries, dependencies, and software updates for integrity before deployment in production environments.
- Implement code signing and integrity verification for all software updates so that tampered packages can be detected before installation.
- Adopt a Zero Trust architecture that limits the lateral movement available to any compromised vendor connection, ensuring that a single supply chain breach cannot propagate across the entire environment.

Against Insider Threats

- Apply the Principle of Least Privilege rigorously — users and systems should have access only to what is strictly necessary for their role, and access rights should be reviewed regularly.
- Deploy User and Entity Behavior Analytics (UEBA) tools that establish behavioral baselines for each user and alert on deviations — such as large data downloads, after-hours access, or unusual system queries.
- Implement Data Loss Prevention (DLP) solutions to monitor, detect, and block unauthorized transfers of sensitive data across email, USB, cloud storage, and other exfiltration channels.
- Establish a clear offboarding process that immediately revokes all system access, credentials, and tokens upon an employee's departure — a step that is frequently overlooked and frequently exploited.

Against DDoS Attacks

- Engage a cloud-based DDoS mitigation service — such as Cloudflare, AWS Shield, or Akamai — that can absorb and filter volumetric attack traffic before it reaches on-premises infrastructure.
- Implement rate limiting, traffic shaping, and IP reputation filtering at the network perimeter to reduce the effectiveness of application-layer DDoS attacks that mimic legitimate user behavior.
- Develop and regularly test a DDoS incident response plan that includes clear escalation paths, communication procedures, and failover configurations to minimize downtime during an active attack.
- Distribute infrastructure using Content Delivery Networks (CDNs) and anycast routing to spread traffic geographically, making it significantly harder to overwhelm any single point of presence.

Against Social Engineering & Deepfakes

- Establish out-of-band verification protocols for any request involving financial transactions, credential resets, or sensitive data access — always verify through a separate, pre-established channel regardless of how convincing the initial request appears.
- Introduce shared verbal codewords or passphrases among senior leadership and finance teams for use in phone and video communications involving sensitive decisions, as demonstrated by Ferrari's post-incident response.
- Conduct regular social engineering simulations — including vishing tests and pretexting exercises — to measure employee susceptibility and reinforce appropriate skepticism toward unsolicited requests.
- Invest in deepfake detection tools and train security teams to recognize artifacts of AI-generated media, while maintaining awareness that detection technology is in an ongoing arms race with generation technology.

6. Conclusion & Future Scope

The five threats examined in this report — AI-powered phishing, supply chain attacks, insider threats, DDoS attacks, and social engineering amplified by deepfake technology — collectively represent the breadth and complexity of the modern cybersecurity challenge. What they share is a common thread: each exploits a form of trust. Trust in familiar voices, trust in software vendors, trust in colleagues, trust in communication channels. Cybersecurity in 2024–2025 is, at its core, a crisis of trust in digital systems.

The pace of change in the threat landscape is accelerating. Artificial intelligence has compressed the timeline between the emergence of a new attack technique and its widespread adoption by criminal groups. Supply chains have grown more interconnected and therefore more fragile. Remote work has permanently blurred the boundary between personal and professional digital environments. Insider risk has grown as organizations expanded access and workforce turnover increased. And deepfake technology has made it genuinely difficult to trust one's own senses when evaluating a digital interaction.

Proactive cybersecurity is no longer a competitive differentiator — it is a basic operational requirement. Organizations that treat security as a periodic compliance exercise rather than a continuous operational discipline will find themselves consistently behind the threat curve. The question is no longer whether an organization will face a serious cyber incident, but whether it will be prepared when it does.

Looking Ahead

Several developments will define the threat landscape over the next three to five years and demand the attention of security professionals entering the field today:

- **Agentic AI Threats:** As AI systems gain the ability to take autonomous actions — browsing, executing code, managing files — they will become both powerful defensive tools and high-value targets for attackers who can compromise or manipulate them.
- **Post-Quantum Cryptography:** The maturation of quantum computing will eventually render current public-key encryption standards obsolete. NIST has already standardized post-quantum algorithms, and organizations must begin migration planning now.
- **Deepfake Legislation and Detection:** Governments worldwide are beginning to legislate against malicious deepfakes, but enforcement remains nascent. Detection technology is advancing rapidly but remains in an arms race with generation technology.
- **Supply Chain Security Standards:** Following incidents like SolarWinds and MOVEit, regulators in the U.S. and EU are introducing mandatory software bill of materials (SBOM) requirements and third-party risk management standards.
- **Human-Centric Security:** As technical defenses improve, attackers will increasingly target the human layer. Security programs that invest in behavior change, psychological resilience, and culture — rather than technology alone — will demonstrate greater long-term effectiveness.

Cybersecurity is a field defined by perpetual learning. The threat actors are studying, adapting, and innovating without pause. The professionals and researchers who stand against them must meet that standard — not as an aspiration, but as a daily practice.

7. References

- [1] IBM Security. (2024). Cost of a Data Breach Report 2024. <https://www.ibm.com/reports/data-breach>
- [2] CISA. (2024). Cybersecurity Alerts & Advisories. <https://www.cisa.gov/news-events/cybersecurity-advisories>
- [3] OWASP. (2021). OWASP Top 10 Web Application Security Risks. <https://owasp.org/www-project-top-ten/>
- [4] KrebsOnSecurity. (2024). Supply chain and insider threat coverage. <https://krebsonsecurity.com>
- [5] Cybersecurity Ventures. (2024). Cybercrime Report 2024–2025. <https://cybersecurityventures.com>
- [6] Ponemon Institute. (2024). 2024 Cost of Insider Risks Global Report.
- [7] Verizon. (2024). Data Breach Investigations Report (DBIR). <https://www.verizon.com/business/resources/reports/dbir/>
- [8] ENISA. (2024). ENISA Threat Landscape 2024. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>
- [9] CISA & NIST. (2024). Software Supply Chain Security Guidance. <https://www.cisa.gov/software-supply-chain-security>
- [10] NIST. (2024). Cybersecurity Framework (CSF) 2.0. <https://www.nist.gov/cyberframework>
- [11] MITRE Corporation. MITRE ATT&CK Framework. <https://attack.mitre.org>
- [12] FBI Internet Crime Complaint Center. (2023). Internet Crime Report 2023. <https://www.ic3.gov>
- [13] Cloudflare. (2024). DDoS Threat Report Q4 2024. <https://www.cloudflare.com/learning/ddos/>
- [14] Wired / Reuters. (2024). Arup deepfake video call fraud — \$25M loss incident coverage.
- [15] U.S. Department of Justice. (2022). Ubiquiti insider extortion case — United States v. Nickolas Sharp.